MODULE 41 · DOMAIN 5 - OPERATIONAL EXCELLENCE AND AUTOMATION

Policy as Code and Drift Remediation

Check infrastructure against rules at every stage, from the developer's laptop to running resources, and put it right automatically when it drifts.

DOMAIN 5 of 5 EXAM WEIGHT 20% MODULE 41 of 52

admin@sthithapragna.com

Catch a violation as **early** as possible, block it where it cannot be bypassed, and **detect and fix** anything that slips through.

Where each tool acts

MOMENT	TOOL	EFFECT
Synthesis	CDK aspects, cdk-nag	Fix or flag constructs in code
Pipeline	cfn-guard, cfn-lint, policy checks	Fail the build
Deployment	CloudFormation Hooks	Warn or block before provisioning
Any API call	SCPs, RCPs, declarative policies	Deny regardless of tool
After creation	AWS Config rules	Detect, then remediate

ON THE EXAM

Hooks cover CloudFormation and Cloud Control API. Console and CLI changes need SCPs or Config.

CDK aspects

- **Visit every construct** in an app before it is synthesised.
- **Fix**: set encryption, tags or removal policies automatically.
- **Flag**: add errors or warnings that stop synthesis.
- **cdk-nag** packages rule packs as aspects.
- **Only CDK apps**: other templates need other checks.

> ON THE EXAM
>
> Enforce or correct a standard across every construct in every CDK app: an aspect.

CloudFormation Hooks

TYPE	RULE WRITTEN IN	FITS
Guard Hook	Guard policy language	Declarative property rules
Lambda Hook	Your Lambda code	Lookups and complex logic
Proactive control Hook	Control Tower Control Catalog	AWS-managed standard rules
Stack-level Hook	Whole template	Rules across resources

ON THE EXAM

Start in warn mode, read the results, then switch to fail.

Detect and remediate with AWS Config

PIECE	ROLE
Managed and custom rules	Evaluate every resource, whatever created it
Proactive evaluation mode	Check a resource definition before creation
Automatic remediation	Run an SSM Automation runbook to fix
Conformance packs	Rules and remediations deployed together
Aggregator	Compliance across accounts and Regions

ON THE EXAM

Resources created any way at all, found and fixed: Config rules with remediation.

Two kinds of drift

DRIFT FROM THE TEMPLATE

Stack resources changed by hand

- CloudFormation drift detection
- Drift-aware change sets revert it
- The template is the truth
- Previewed before applied

DRIFT FROM POLICY

Any resource breaking a rule

- Config rules detect it
- Remediation runbooks fix it
- The rule is the truth
- Covers resources outside stacks

THE TIEBREAKER

A stack resource changed in the console: drift-aware change set. Any resource breaking a rule: Config remediation.

Reading the scenario

WHEN THE QUESTION SAYS	IT IS TESTING
Fix every CDK construct automatically	CDK aspect
Block bad resources before provisioning	CloudFormation Guard Hook
Rule needs a lookup or custom logic	Lambda Hook
Created by hand, found and fixed	Config rule with remediation
Roll out a new rule without breaking teams	Hook in warn mode first
Deny regardless of tool used	SCP, RCP or declarative policy

ON THE EXAM

Earliest friendly check, unbypassable block, and detection with fix.

> Meridian Freight's 30 teams build infrastructure with the AWS CDK. Security requires every S3 bucket to have encryption, versioning and access logging.
>
> The platform team wants this applied automatically in every app, before templates are produced, without each team writing it.

What should the solutions architect implement?

A. An SCP denying s3:CreateBucket without encryption headers

B. An AWS Config rule for bucket settings

C. A CDK aspect in a shared library that sets these properties on every bucket construct

D. A code review checklist

◆ PAUSE AND DECIDE

What should the solutions architect implement?

A **SCP**

Blocks at the API, but does not apply settings, and covers one of three.

B **Config rule**

Acts after deployment, not before templates exist.

C **CDK aspect**

Applies the settings to every bucket at synthesis, automatically.

D **Checklist**

Manual and inconsistent.

THE SIGNAL

Applied automatically in CDK apps before synthesis: an aspect.

> Some Meridian Freight teams use CloudFormation directly and others use Terraform with the AWS Cloud Control provider. Security wants any RDS instance without storage encryption rejected before it is provisioned, in all accounts.
>
> The rule is a simple check of resource properties.

What should the solutions architect implement?

A. A CloudFormation Guard Hook in fail mode, deployed to all accounts

B. A CDK aspect

C. An AWS Config rule with remediation

D. A monthly compliance report

◆ PAUSE AND DECIDE

What should the solutions architect implement?

A Guard Hook, fail mode

Blocks before provisioning, for CloudFormation and Cloud Control API.

B CDK aspect

These teams do not use the CDK.

C Config remediation

Acts after the instance exists; encryption cannot be added in place.

D Monthly report

Too late, and not enforcement.

THE SIGNAL

Block before provisioning, CloudFormation and Cloud Control users alike: a Guard Hook.

> Meridian Freight only allows EC2 instances launched from AMIs in its approved catalogue, a DynamoDB table updated daily by the image team.
>
> Stacks that reference any other AMI must be stopped before resources are created.

What should the solutions architect implement?

A. A Guard Hook with the AMI IDs written into the rule

B. An SCP listing allowed AMI IDs

C. A CDK aspect

D. A Lambda Hook that checks each AMI ID against the catalogue table

◆ PAUSE AND DECIDE

What should the solutions architect implement?

A Guard with fixed IDs

Out of date the day after each catalogue change.

B SCP with ID list

Edited daily, and policy size limits bite.

C CDK aspect

Only for CDK apps, and still needs the lookup.

D Lambda Hook

Code can query the live catalogue at deployment time.

THE SIGNAL

A rule that needs a live lookup: Lambda Hook.

> An audit found security groups allowing SSH from the internet in several Meridian Freight accounts, created by hand in the console over the years. Hooks did not catch them.
>
> Security wants all such rules found across accounts, and removed automatically.

What should the solutions architect implement?

A. A stricter CloudFormation Hook

B. An AWS Config rule for unrestricted SSH, with automatic remediation through an SSM Automation runbook, deployed organisation-wide

C. A drift-aware change set on every stack

D. A CDK aspect

◆ PAUSE AND DECIDE

What should the solutions architect implement?

A Stricter Hook

Hooks never see console changes.

B Config with remediation

Finds every such rule, however created, and removes it.

C Drift-aware change sets

Only for stack resources; these were made by hand.

D CDK aspect

Only affects CDK apps.

THE SIGNAL

Created outside IaC, found and fixed: Config rules with remediation.

> Meridian Freight's security team has written 25 new Guard rules. Nobody knows how many existing deployments would fail them.
>
> The team wants to enforce the rules without suddenly breaking dozens of pipelines.

How should the solutions architect roll out the Hooks?

A. Activate all 25 in fail mode immediately

B. Ask teams to run the rules locally first

C. Activate the Hooks in warn mode, review invocation results and annotations, help teams fix findings, then switch to fail mode

D. Apply the rules only to new accounts

◆ PAUSE AND DECIDE

How should the solutions architect roll out the Hooks?

A Fail immediately

Breaks many pipelines at once.

B Local runs

Voluntary; no central picture.

C Warn, review, then fail

Measures impact safely, then enforces.

D New accounts only

Leaves existing risk unaddressed.

THE SIGNAL

New enforcement rules: warn mode first, results reviewed, then fail.

> Meridian Freight must guarantee that nobody can turn off S3 Block Public Access at account level or delete CloudTrail trails, whether they use CloudFormation, Terraform, the CLI or the console.
>
> The guarantee must hold in every member account.

Which policy-as-code layer should the solutions architect use?

A. An SCP denying s3:PutAccountPublicAccessBlock and cloudtrail:DeleteTrail, with a break-glass exception

B. A CloudFormation Hook

C. A CDK aspect

D. A Config rule with remediation

◆ PAUSE AND DECIDE

Which policy-as-code layer should the solutions architect use?

A SCP
Denies the API call itself, whatever tool makes it.

B Hook
Misses the CLI and console.

C Aspect
Only CDK apps.

D Config remediation
Repairs after the fact; a window exists.

THE SIGNAL

Guarantee across every tool: deny at the API with an organisation policy.

What to carry out of this module

- **Layers**: aspects, pipeline checks, Hooks, organisation policies, Config.
- **Guard Hooks** for property rules; **Lambda Hooks** for lookups.
- **Hooks miss console and CLI**; SCPs and Config cover them.
- **Warn mode first**, then fail, for new rules.
- **Template drift**: drift-aware change sets. **Policy drift**: Config remediation.

> ON THE EXAM
>
> Earliest friendly check, unbypassable block, detection and repair.